



Institut des Carrières Commerciales — Bruxelles · Travail de fin d'études

BikeShare

Plateforme de location de vélos entre particuliers

Stratégie de sécurité

Authentification · Données · RGPD

Yassin Iallalen

Stratégie de sécurité

Ce document décrit les mesures de sécurité mises en œuvre dans **BikeShare** pour protéger les comptes, les données personnelles et les transactions.

1. Authentification & autorisation

- **Spring Security** gère l'authentification et le contrôle d'accès basé sur les rôles (`ROLE_VISITOR` , `ROLE_MEMBER` , `ROLE_ADMIN`).
- Les mots de passe sont chiffrés avec **BCrypt** (jamais stockés en clair).
- Les routes sont protégées par `SecurityFilterChain` : zones publiques, espace membre et espace administrateur cloisonnés.
- Évolution prévue : **JWT** pour une API sans état.

2. Protection des données

- Données bancaires (IBAN/BIC) non exposées ; paiements délégués à **Stripe** (aucune donnée carte stockée côté serveur).
- Validation des entrées (annotations `@NotBlank` , `@Pattern` , `@Size`) pour prévenir les données malformées.
- Vérification d'identité des profils via documents (table `documents`).

3. Sécurité applicative

Risque	Mesure
Injection SQL	Requêtes paramétrées via Spring Data JPA / Hibernate.
Accès non autorisé	Contrôle par rôle sur chaque endpoint sensible.
Détournement de session	Gestion de session sécurisée, HTTPS recommandé en production.
Téléversement malveillant	Limitation de taille et stockage isolé des fichiers (FileStorageService).

4. Conformité RGPD

- Minimisation des données collectées et finalité explicite.
- Consentement de l'utilisateur lors de l'inscription.
- Droit d'accès, de rectification et à l'effacement des données.
- Conservation limitée des données aux durées nécessaires.

Recommandations de production : forcer HTTPS (TLS), activer la protection CSRF pour les formulaires, journaliser les accès sensibles, et mettre en place une politique de mots de passe robuste.